

W10D4 - Raccolta Informazioni

metasploitable - recon

Multiple tests

Danilo 'danix' Macrì - me@mio.sito

Scan started on 12/09/2025 - duration (days): 1

Contents

W10D4 - Raccolta Informazioni	1
metasploitable - raccolta informazioni	1
Sommaro	1
Oggetto del test (scope)	1
I test	1
1) nmap -sn -PE <target>	1
2) nmap <target> -top-ports 10 -open	2
3) nmap -sS -sV -T4 <target>	3
4) netexec {smb,ssh,nfs} <target>	4

W10D4 - Raccolta Informazioni

metasploitable - raccolta informazioni

Sommario

Con l'esercizio di oggi andremo a testare la macchina Metasploitable (192.168.50.101) alla ricerca di vulnerabilità, tramite l'utilizzo di alcuni dei diversi esempi elencati al seguente indirizzo:

- <https://www.yeahhub.com/15-most-useful-host-scanning-commands-kalilinux/>

Oggetto del test (scope)

La macchina oggetto dei nostri test sarà la metasploitable all'indirizzo:

- 192.168.50.101

I test

1) nmap -sn -PE <target>

```
(kali㉿kali)-[~]  
$ nmap -sn -PE 192.168.50.0/24  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-30 03:49 EDT  
Nmap scan report for metasploitable (192.168.50.101)  
Host is up (0.00017s latency).  
MAC Address: 08:00:27:B5:7A:73 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.50.100  
Host is up.  
Nmap done: 256 IP addresses (2 hosts up) scanned in 17.83 seconds
```

Questo primo test ci serve per enumerare le macchine attive nella rete che stiamo testando, dallo screenshot si evince che abbiamo passato come target tutta la nostra sottorete, e nmap ci ha riportato 2 macchine attive, la metasploitable all'indirizzo 192.168.50.101 e la nostra kali all'indirizzo 192.168.50.100.

2) nmap <target> -top-ports 10 -open

```
(kali㉿kali)-[~]  
$ nmap metasploitable -top-ports 10 -open  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-30 03:55 EDT  
Nmap scan report for metasploitable (192.168.50.101)  
Host is up (0.00011s latency).  
Not shown: 3 closed tcp ports (reset)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
22/tcp    open  ssh  
23/tcp    open  telnet  
25/tcp    open  smtp  
80/tcp    open  http  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
MAC Address: 08:00:27:B5:7A:73 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.38 seconds
```

Questa scansione mirata alla macchina metasploitable ci permette di testare le 10 porte più popolari e verificare se ci sono servizi in ascolto, è una scansione molto veloce che però potrebbe lasciare fuori qualche servizio interessante.

3) nmap -sS -sV -T4 <target>

```
(kali㉿kali)-[~]
$ nmap -sS -sV -T4 metasploitable
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-30 03:59 EDT
Nmap scan report for metasploitable (192.168.50.101)
Host is up (0.000054s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet?
25/tcp    open  smtp?
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login?
514/tcp   open  shell?
1099/tcp  open  java-rmi      GNU Classpath grmiregistry
1524/tcp  open  bindshell     Metasploitable root shell
2049/tcp  open  nfs           2-4 (RPC #100003)
2121/tcp  open  ccproxy-ftp?
3306/tcp  open  mysql?
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6000/tcp  open  X11           (access denied)
6667/tcp  open  irc           UnrealIRCd
8009/tcp  open  ajp13         Apache Jserv (Protocol v1.3)
8180/tcp  open  unknown
MAC Address: 08:00:27:B5:7A:73 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 181.04 seconds
```

Questa scansione utilizza l'opzione SYN scan -sS, è una scansione che inizializza il 3-way handshake con ogni servizio, inviando il pacchetto iniziale SYN, poi se riceve in risposta il pacchetto SYN-ACK dal server, lascia cadere la connessione senza completare l'handshake, inviando il pacchetto RST.

Abbiamo aggiunto l'opzione -sV per fare in modo che nmap testi i servizi attivi in modo da restituire la versione del demone in ascolto. In questo modo possiamo vedere subito se ci sono servizi vulnerabili o altre falle di sicurezza.

L'ultima opzione è -T4 che istruisce nmap sulla velocità con cui eseguire i test. Nmap usa una scala di timing da 0 a 5, dove 0 è il tempo più lungo, permettendo al programma di non essere rilevato da un eventuale software IDS, e 5 è il timing più breve, per accorciare la durata di un test usando diverse strategie tra cui l'invio di pacchetti multipli.

4) netexec {smb,ssh,nfs} <target>

```
(kali@kali)-[~]  
$ netexec smb 192.168.50.101  
SMB 192.168.50.101 445 METASPLOITABLE [*] Unix (name:METASPLOITABLE) (domain:localdomain) (signing:False) (SMBv1:True)
```

```
(kali@kali)-[~]  
$ netexec ssh 192.168.50.101  
SSH 192.168.50.101 22 192.168.50.101 [*] SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
```

```
(kali@kali)-[~]  
$ netexec nfs 192.168.50.101  
NFS 192.168.50.101 33183 192.168.50.101 [*] Supported NFS versions: (2, 3, 4) (root escape:True)
```

Uno dei comandi suggeriti nel link iniziale è cracmapexec, utility che permette di testare reti composte da macchine windows, alla ricerca di informazioni su Active Directory, dump di credenziali ecc. Siccome questa utility non è più attivamente sviluppata, ho deciso di utilizzare **netexec** un suo fork più generico che include diversi sistemi di scansione, tra cui scansioni per vari servizi tra cui **samba**, **ssh** e **nfs**.

Negli screenshot sopra si vede l'output del riconoscimento dei servizi aperti e successivamente, per ogni servizio, si può poi procedere a testare l'accesso in brute force con dizionari precompilati, si può testare l'esecuzione remota di comandi, il dump delle credenziali e persino l'esecuzione di comandi impersonando altri utenti connessi al server.

Con questo si conclude la nostra fase di ricognizione della macchina metasploitable.

Alla prossima.

